

Gestion des tiers, infogérance et EBIOS RM (Ateliers 3-4)

De la conception au contrôle des tiers déjà là

Le contrat d'infogérance

tenir le tiers déjà installé

Les ateliers 3 et 4

raconter par où il pourrait trahir

La maîtrise des tiers

Objectifs de la séance

À l'issue de ce TD :



- **Analyser** un contrat d'infogérance sous l'angle de la sécurité, et repérer ce qui manque à une prestation existante du groupe
- **Construire** la cartographie de dangerosité de l'écosystème d'un objet d'étude MERIDIAN et sélectionner ses parties prenantes critiques
- **Élaborer** un scénario stratégique, de la source de risque à l'événement redouté, en passant par une partie prenante critique

Prérequis

- Le cours magistral de ce matin : Security by Design, jalons de sécurité, et les trois régimes acheter / développer / faire développer.
- L'appréciation du risque de la séance 5 : le dossier D5, avec le cadrage, les échelles de gravité et de vraisemblance justifiées, le socle de sécurité, les valeurs métier et biens supports repris de la séance 2, et les couples source de risque / objectif visé (SR/OV) retenus aux ateliers 1 et 2.
- La cartographie de la séance 2 : sa vue de l'écosystème est l'entrée directe de l'atelier 3.
- Le rapport d'audit de la séance 4, dont les écarts nourrissent le socle de sécurité.
- L'extrait de contrat de la filiale instruite, fourni dans le dossier de référence (sous-dossier « Contrats-infogérance ») et en ligne sous /assets/tp/contrats/.

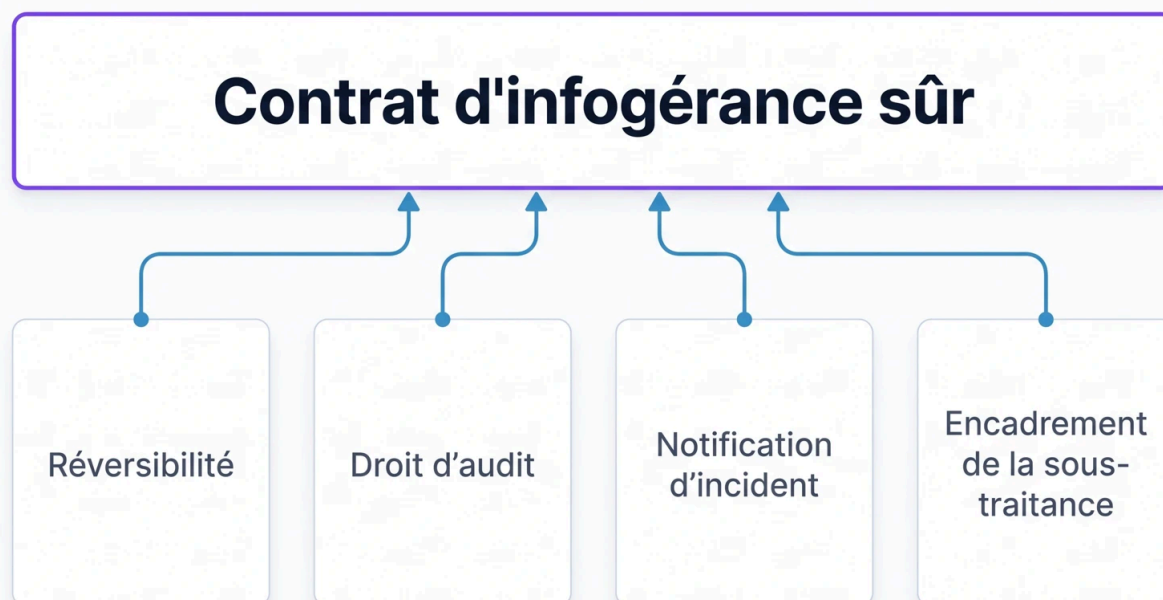
✓ Ce qu'il faut poser avant de manipuler

Dix minutes de cadrage, pas plus. Le cours de ce matin a intégré la sécurité aux projets ; ce TD s'occupe des tiers durablement installés, ceux que le régime « faire développer ou infogérer » désigne, et il fait entrer dans les ateliers 3 et 4 de la méthode d'analyse de risque, sous l'angle de l'écosystème. Trois notions à poser, que le CM a laissées de côté.

Le contrat d'infogérance d'abord. L'infogérance, selon le guide de l'ANSSI (Agence nationale de la sécurité des systèmes d'information) « Maîtriser les risques de l'infogérance », est « l'externalisation appliquée au domaine des systèmes d'information », c'est-à-dire le fait de « confier à un tiers tout ou partie d'une activité qui jusqu'alors était réalisée en interne ». Le contrat d'infogérance est l'acte qui règle cette délégation. Sa mécanique de sécurité tient dans une idée que le guide martèle : ce qui n'est pas exigé au contrat ne sera jamais dû. Le donneur d'ordres apprécie ses risques, en déduit des exigences de sécurité, les inscrit au cahier des charges, et demande aux candidats un document contractuel, le Plan d'Assurance Sécurité, qui « décrit l'ensemble des dispositions spécifiques que les candidats s'engagent à mettre en œuvre pour garantir le respect des exigences de sécurité du donneur d'ordres ».

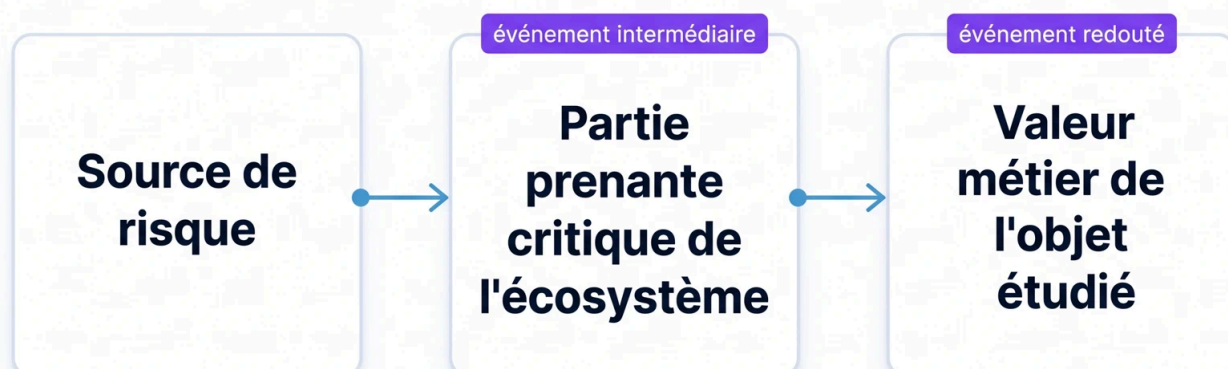
Quatre exigences reviennent partout et forment la colonne vertébrale d'un contrat d'infogérance sûr : la réversibilité (pouvoir « reprendre la gestion de la fonction externalisée, soit pour l'exploiter directement, soit pour en confier l'exploitation à un tiers de son choix »), le droit d'audit (« Le client doit pouvoir, à tout moment, contrôler

que les exigences de sécurité sont satisfaites », la notification d'incident (« le client doit être tenu informé sans délai en cas d'attaque afin de déclencher le circuit de réaction adéquat »), et l'encadrement de la sous-traitance (se réserver « le droit de récuser tout sous-traitant ne présentant pas les garanties suffisantes »). La limite : un contrat parfait sur le papier ne vaut que par le comité de suivi qui le fait vivre et les audits qui le vérifient.



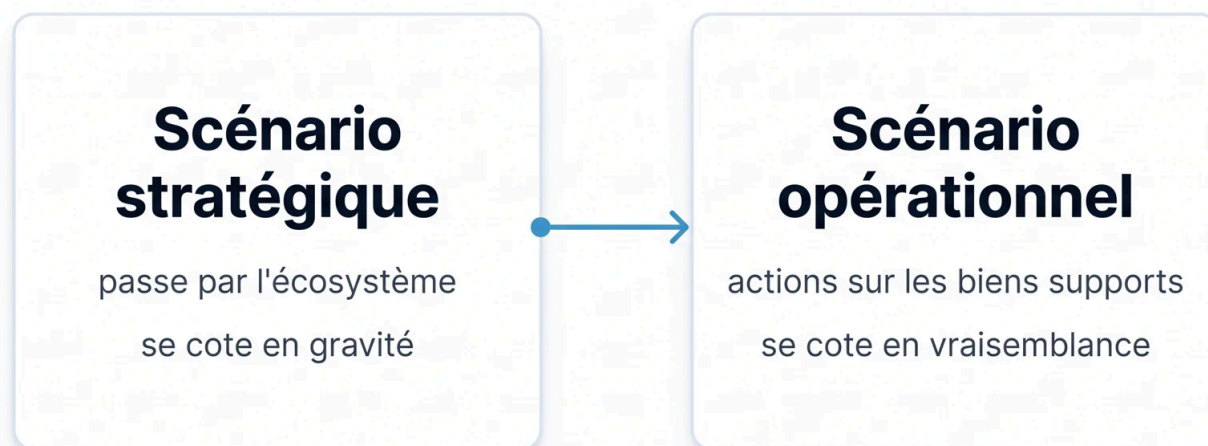
Les ateliers 3 et 4 de la méthode, ensuite, abordés ici et cet après-midi. La séance 5 a présenté les deux premiers ateliers d'EBIOS Risk Manager : l'atelier 1 a cadré l'étude, posé les valeurs métier, les biens supports, les événements redoutés et le socle de sécurité ; l'atelier 2 a identifié les couples source de risque / objectif visé. L'**atelier 3** prend le relais : selon le guide, « L'objectif de l'atelier 3 est de disposer d'une vision claire de l'écosystème, afin d'identifier et de présenter les parties prenantes les plus menaçantes à la direction. Il s'agit ensuite de bâtir des scénarios de haut niveau, appelés scénarios stratégiques. » Sa mécanique : on estime la dangerosité de chaque partie prenante de l'écosystème, on en sélectionne les parties prenantes critiques, puis on trace pour chaque couple SR/OV des chemins d'attaque.

Une **partie prenante critique** est celle « susceptible de constituer un vecteur d'attaque pertinent, du fait par exemple de son accès numérique privilégié à l'objet étudié, de sa vulnérabilité ou de son exposition ». Un **scénario stratégique** est, selon le glossaire du guide, un ensemble de « chemins d'attaque allant d'une source de risque à un objectif visé en passant par l'écosystème et les valeurs métier de l'objet étudié », et il « est estimé en termes de gravité ». C'est très exactement l'attaque par rebond de ce matin, formalisée : le chemin qui passe par le maillon faible de l'écosystème.



Le scénario stratégique se cote en gravité

L'atelier 4, enfin, seulement effleuré ici, et que l'après-midi outillera. Son objet, selon le guide : « construire des scénarios opérationnels [qui] schématisent les modes opératoires que pourraient mettre en œuvre les sources de risque pour réaliser les scénarios stratégiques ». Un **scénario opérationnel** est « un enchaînement d'actions élémentaires portées sur les biens supports », et il « est estimé en termes de vraisemblance ». Le lien entre les deux ateliers est net : « À chaque chemin d'attaque stratégique retenu dans l'atelier 3 correspond un scénario opérationnel. » Le scénario stratégique dit par où l'attaque passe (l'écosystème) ; le scénario opérationnel dit comment elle se fait techniquement (les biens supports).



À chaque chemin d'attaque correspond un scénario opérationnel

Un chiffre pour mesurer l'enjeu avant d'agir : selon le baromètre CESIN (club des experts de la sécurité de l'information et du numérique) de 2022, 24 % des entreprises citaient l'attaque par rebond via un prestataire parmi les moyens de transmission des attaques qu'elles avaient subies. La partie prenante critique n'est pas une abstraction de méthode : c'est une porte d'entrée réelle, mesurée.

Tout est en place : un contrat pour tenir un tiers, une méthode pour raconter par où il pourrait trahir le groupe. Les exercices déroulent cette chaîne, du contrat au scénario.

✓ Exercice 1 : le contrat du prestataire le plus exposé de la filiale instruite (15 minutes)

Reprendre l'extrait de contrat du prestataire le plus exposé de la filiale instruite, fourni pour chaque filiale dans le sous-dossier « Contrats-infogérance » du dossier de référence et sous /assets/tp/contrats/. Ce que l'extrait ne stipule pas, le contrat ne le stipule pas. À partir des quatre familles d'exigences d'un contrat d'infogérance sûr, réversibilité, droit d'audit, notification d'incident et encadrement de la sous-traitance, établir pour ce contrat les exigences vérifiables qui manquent et l'écart que chacune corrige, en s'appuyant sur l'extrait et sur ce que le dossier de filiale établit. Formuler des exigences vérifiables, non des clauses juridiques.

À produire : un tableau à trois colonnes, famille, exigence vérifiable, écart corrigé, plus une ligne libre pour l'exigence la plus urgente, justifiée en une phrase.

✓ Exercice 2 : la cartographie de dangerosité et un scénario stratégique (20 minutes)

Prendre pour objet d'étude l'actif critique n°1 de la filiale instruite, la valeur métier dont l'événement redouté est coté le plus haut au dossier D5. Lire son écosystème aux §3 et §6 du dossier de filiale et retenir au moins quatre parties prenantes. Estimer la dangerosité de chacune sur l'exposition et la fiabilité cyber, les classer, puis désigner la ou les parties prenantes critiques selon un seuil que le groupe fixe et écrit. Tracer ensuite, pour le couple source de risque / objectif visé retenu en séance 5, un scénario stratégique qui passe par une partie prenante critique, et en coter la gravité sur l'échelle du D5, de G1 mineur à G4 critique.

À produire : la cartographie de dangerosité classée avec ses parties prenantes critiques désignées, et un scénario stratégique coté en gravité.

 **Corrigés et critères d'évaluation** – cliquer pour révéler